

Security+ 1.4 · Public Key Infrastructure (PKI)

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · Aula 1.4 — Public Key Infrastructure (PKI) (9:08) · [Vídeo no YouTube ↗](#)

Resumo da Aula: PKI: o fundamento da criptografia moderna — SIMÉTRICA (AES — mesma chave, rápida, boa pra volume) vs ASSIMÉTRICA (RSA/ECC — par de chave pública/privada, lenta, boa pra troca e assinatura). Key escrow = cópia de chave em cofre.

Highlights que a prova cobra

- AES = simétrico; RSA = assimétrico
- Assimétrico: pública cifra, privada decifra (ou assina)
- PGP: combina a 2 (RSA pra trocar a chave + AES pro conteúdo)

Dicas de prova & Cenários Típicos

- 'requires a mathematical relationship between two cryptographic keys' = assimétrica (PKI)
- AES vs RSA: não confunde — a prova gosta de citar algoritmos

Cenário clássico de exame: Cenário típico: 'empresa precisa que a mensagem só possa ser aberta pelo destinatário, sem compartilhar senha' → crypto assimétrica (par de chave).

🚨 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Seção 1.4)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer (Public Key Infrastructure (PKI)) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Criptografia Simétrica (AES-256, ChaCha20):** Usa uma única chave idêntica para cifrar e decifrar. Excelente para confidencialidade de grandes volumes (BitLocker, banco de dados, túneis VPN). **Atenção de prova:** cifras simétricas NÃO oferecem não-repúdio quando a chave é compartilhada.
- **Criptografia Assimétrica (RSA, ECC, Ed25519):** Usa par de chaves matemáticas: a Chave Pública é distribuída livremente; a Chave Privada é mantida em segredo absoluto pelo titular. Assinar o hash com a chave privada garante **Não-repúdio e Autenticidade**. Cifrar com a chave pública do destinatário garante **Confidencialidade**.
- **Hashing (SHA-256, SHA-3) vs. HMAC:** Hash puro é função matemática unidirecional sem chave, garantindo apenas integridade (qualquer um pode recalculá-lo de um dado adulterado). O HMAC combina hash com chave simétrica secreta, provendo integridade e autenticação mútua entre sistemas conhecidos.
- **TSA (Time Stamping Authority - RFC 3161) e LTV:** Entidade confiável que assina o hash com data/hora auditada, provando o momento exato em que o documento existiu e garantindo validação de longo prazo (LTV) mesmo após a expiração de certificados.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Hash puro NÃO fornece não-repúdio.
- AES com chave compartilhada destrói o não-repúdio.
- Políticas em papel e termos de adesão são controles puramente administrativos; não bloqueiam ataques em tempo de execução.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

1. AES é um exemplo de criptografia:

- A)** Simétrica (mesma chave cifra e decifra)
- B)** Assimétrica (par de chaves)
- C)** Hash de mão única
- D)** Codificação Base64

2. Qual tipo de criptografia usa pares de chaves pública e privada?

- A)** Hashing
- B)** Criptografia simétrica
- C)** Criptografia assimétrica
- D)** Steganografia

3. Em uma infraestrutura PKI, qual componente é responsável por validar e revogar certificados digitais?

- A)** RA (Registration Authority)
- B)** CA (Certificate Authority)
- C)** CRL (Certificate Revocation List)
- D)** OCSP (Online Certificate Status Protocol)

4. Trocar uma chave secreta por canal público SEM enviá-la diretamente usa:

- A)** Diffie-Hellman
- B)** AES
- C)** SHA-256
- D)** Base64

5. Serviço que gerencia chaves de criptografia na nuvem (criar, rotacionar, controlar acesso):

- A)** KMS (Key Management Service)
- B)** IAM
- C)** CDN
- D)** VPC

6. Cenário corporativo (Public Key Infrastructure (PKI)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'AES = simétrico; RSA = assimétrico'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: AES = simétrico; RSA = assimétrico...

7. Cenário corporativo (Public Key Infrastructure (PKI)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'Assimétrico: pública cifra, privada decifra (ou assina)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Assimétrico: pública cifra, privada decifra (ou assina)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Public Key Infrastructure (PKI)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'PGP: combina a 2 (RSA pra trocar a chave + AES pro conteúdo)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: PGP: combina a 2 (RSA pra trocar a chave + AES pro conteúdo)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Public Key Infrastructure (PKI)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'requires a mathematical relationship between two cryptographic keys' = assimétrica (PKI). Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'requires a mathematical relationship between two cryptographic keys' = ass...

10. Cenário corporativo (Public Key Infrastructure (PKI)): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 1.4), um analista avalia o seguinte requisito técnico: 'AES vs RSA: não confunde — a prova gosta de citar algoritmos'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: AES vs RSA: não confunde — a prova gosta de citar algoritmos...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

1) A — Simétrica (mesma chave cifra e decifra).

✓ **Por que está certa:** AES é simétrica: a MESMA chave cifra e decifra — rápida, boa pra volume. Assimétrica (RSA) usa par pública/privada. Hash não é criptografia reversível; Base64 é só codificação.

✗ **Por que as outras estão erradas:**

- *Assimétrica (par de chaves):* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Hash de mão única:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Codificação Base64:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

2) C — Criptografia assimétrica.

✓ **Por que está certa:** Criptografia assimétrica (como RSA, ECC) usa par de chaves matematicamente relacionadas: pública para criptografar e privada para descriptografar, ou vice-versa para assinatura.

✗ **Por que as outras estão erradas:**

- *Hashing:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Criptografia simétrica:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Steganografia:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

3) B — CA (Certificate Authority).

✓ **Por que está certa:** A CA (Autoridade Certificadora) emite, valida e revoga certificados. A RA apenas verifica identidades, enquanto CRL e OCSP são mecanismos de verificação de revogação.

✗ **Por que as outras estão erradas:**

- *RA (Registration Authority):* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *CRL (Certificate Revocation List):* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *OCSP (Online Certificate Status Protocol):* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

4) A — Diffie-Hellman.

✓ **Por que está certa:** Diffie-Hellman deixa duas partes derivarem a MESMA chave secreta trocando só valores públicos. Base da troca de chave do TLS.

✗ **Por que as outras estão erradas:**

- *AES:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *SHA-256:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Base64:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

5) A — KMS (Key Management Service).

✓ **Por que está certa:** KMS centraliza as chaves de criptografia (at rest), integra com storage/banco, e audita o uso.

✗ **Por que as outras estão erradas:**

- *IAM:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *CDN:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *VPC:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

6) D — Implementar a solução correspondente: AES = simétrico; RSA = assimétrico....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Public Key Infrastructure (PKI)): AES = simétrico; RSA = assimétrico.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) C — Implementar a solução correspondente: Assimétrico: pública cifra, privada decifra (ou assina)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Public Key Infrastructure (PKI)): Assimétrico: pública cifra, privada decifra (ou assina).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) C — Implementar a solução correspondente: PGP: combina a 2 (RSA pra trocar a chave + AES pro conteúdo)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Public Key Infrastructure (PKI)): PGP: combina a 2 (RSA pra trocar a chave + AES pro conteúdo).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) D — Implementar a solução correspondente: 'requires a mathematical relationship between two cryptographic keys' = ass....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Public Key Infrastructure (PKI)): 'requires a mathematical relationship between two cryptographic keys' = assimétrica (PKI).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) B — Implementar a solução correspondente: AES vs RSA: não confunde — a prova gosta de citar algoritmos....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 1.4 (Public Key Infrastructure (PKI)): AES vs RSA: não confunde — a prova gosta de citar algoritmos.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

